

מודול 1 — מבוא, מעבדה ומתודולוגיה — תרגילים ופתרונות

חומר לימוד

2 יחידות

תוכן העניינים

1.  תרגילים — מודול 1: מבוא, מעבדה ומתודולוגיה

2.  פתרונות מלאים — מודול 1

🎯 תרגילים — מודול 1: מבוא, מעבדה ומתודולוגיה

כל התרגילים מתבצעים במעבדה שלך בלבד. הפתרונות המלאים צעד-אחר-צעד נמצאים ב- [solutions.md](#) — נסה לבד לפני שתציץ!

מקרא רמות: קל ● בינוני ● מתקדם ● אתגר ●

חלק א' — שאלות ידע (קל ●)

תרגיל 1.1 — מהם שלושת עקרונות ה-CIA Triad? תן דוגמה לפגיעה בכל אחד.

תרגיל 1.2 — מה ההבדל בין האקר White Hat ל-Grey Hat?

תרגיל 1.3 — הסבר במילים שלך את ההבדל בין **Vulnerability**, **Exploit** ו-**Payload**, בעזרת דוגמת "הדלת הנעולה".

תרגיל 1.4 — מנה את חמשת שלבי ההאקינג האתי בסדר הנכון.

תרגיל 1.5 — לאיזה שלב שייכת כל פעולה? - (א) חיפוש עובד ב-LinkedIn - (ב) הרצת nmap על שרת - (ג) מחיקת קובצי לוג - (ד) הוספת משתמש חדש כדי לחזור מאוחר יותר - (ה) הפעלת Exploit ב-Metasploit

חלק ב' — הקמת הסביבה (●●)

תרגיל 2.1 ● — התקן את Kali Linux ב-VMware/VirtualBox, התחבר, ופתח Terminal.

תרגיל 2.2 ● — עדכן את Kali בפקודה אחת.

תרגיל 2.3 ● — הגדר את מתאם הרשת ל-Host-Only או NAT, הרץ `ip a`, וזהה את כתובת ה-IP הפרטית שלך. ציין לאיזה טווח פרטי היא שייכת.

תרגיל 2.4 ● — קח **Snapshot** של המכונה במצב נקי, ותן לו שם משמעותי. הסבר במשפט למה זה חשוב.

חלק ג' — היכרות עם Kali (בינוני ●)

תרגיל 3.1 — נווט בתפריט **Applications** ואתר כלי אחד בכל קטגוריה: Information Gathering, Password Attacks, Exploitation Tools.

תרגיל 3.2 — מצא את הקובץ `rockyou.txt` במערכת. באיזו תיקייה הוא? (רמז: `/usr/share/wordlists`). כמה שורות (סיסמאות) יש בו?

תרגיל 3.3 — לכל אחת מהקטגוריות הבאות, לאיזה **שלב** מחמשת השלבים היא שייכת בעיקר? Information Gathering · Exploitation Tools · Post Exploitation

חלק ד' — חשיבה מתודולוגית (מתקדם)

תרגיל 4.1 — קיבלת בדיקת חדירות על החברה "Acme". נתנו לך רק את הדומיין `acme.com` וללא שום פרטי גישה. (א) איזה סוג בדיקה זה (Black/Grey/White Box)? (ב) איזה פרופיל תוקף אתה מדמה? (ג) מה תהיה הפעולה הראשונה שלך, ולאיזה שלב היא שייכת?

תרגיל 4.2 — הלקוח מבקש שתבדוק אם עובדים ייפלו בפשינג, ובנוסף שתבדוק את שרת ה-Web החיצוני. אילו שני סוגי **Engagement** אלה?

תרגיל 4.3 — במהלך בדיקה גילית בטעות שרת שאינו מופיע ב-Scope, והוא פגיע מאוד. מה מותר לך לעשות ומה אסור? נמק.

אתגר מסכם — "תוכנית בדיקה + מעבדה מתועדת"

הפק מסמך קצר (Word/Markdown/צילומי מסך) הכולל:

1. מעבדה מתועדת:

- צילום מסך של Kali פועל עם Terminal.
- פלט `ip a` עם ה-IP הפרטי מסומן.
- פלט `uname -a` (גרסת Kernel).
- הוכחה שלקחת Snapshot.

2. טבלת מתודולוגיה: חמשת השלבים, ולכל שלב — מטרה במשפט + כלי אחד + דוגמה.

3. **תרחיש:** בהינתן בדיקת חדירות Black Box על `acme.com`, כתוב תוכנית פעולה בת 5 שורות — שורה לכל שלב — מה תעשה בכל שלב.

4. **הצהרת אתיקה:** פסקה שמסבירה מדוע המעבדה שלך מבודדת, ואילו מסמכים משפטיים נדרשים לפני בדיקה אמיתית.

רשימת בקרה — לפני מעבר למודול 2 ✓

- ☐ אני מבין את ה-CIA Triad ומכיר את סוגי ההאקרים והבדיקות
- ☐ אני יודע להסביר Vulnerability / Exploit / Payload
- ☐ אני יכול לדקלם את חמשת השלבים בסדר הנכון
- ☐ Kali מותקן, מעודכן, מבודד ברשת, ויש Snapshot נקי
- ☐ אני יודע לפתוח Terminal ולמצוא כלים ו-wordlists
- ☐ קראתי והבנתי את ההיבטים המשפטיים

הפתרונות המלאים: `solutions.md`

פתרונות מלאים — מודול 1 ✓

נסה לפתור לבד ב- `missions.md` לפני שתקרא כאן. הפתרונות מפורטים צעד-אחר-צעד.

חלק א' — שאלות ידע

פתרון 1.1 — CIA Triad - Confidentiality (סודיות): רק מורשים רואים מידע. **פגיעה:** דלף מסד נתונים של סיסמאות. **Integrity (שלמות):** המידע אינו משתנה ללא הרשאה. **פגיעה:** שינוי סכום בהעברה בנקאית. **Availability (זמינות):** המערכת זמינה. **פגיעה:** מתקפת DoS שמפילה את השרת.

פתרון 1.2 — White Hat vs Grey Hat **White Hat** פועל **בהרשאה מלאה** ובחזרה. **Grey Hat** פועל **ללא הרשאה** אך לרוב ללא כוונת זדון (למשל מוצא חולשה במערכת של אחר ומדווח עליה) — אך עצם הפעולה ללא רשות היא **בלתי חוקית**.

פתרון 1.3 — Vulnerability - Vulnerability / Exploit / Payload = הפגם. דלת עם מנעול פגום. - **Exploit** = ניצול הפגם. שיטת פריצת המנעול. - **Payload** = מה שקורה אחרי. מה שאתה עושה בפנים — גונב/מצלם. נוסחה: `Vulnerability + Exploit + Payload = גישה`.

פתרון 1.4 — חמשת השלבים (בסדר) 1. Reconnaissance (איסוף מידע) 2. Scanning & Enumeration (סריקה ומיפוי) 3. Gaining Access (השגת גישה) 4. Maintaining Access (שמירת גישה) 5. Covering Tracks (טשטוש עקבות)

פתרון 1.5 — שיוך פעולות לשלבים - (א) **Reconnaissance** → LinkedIn (פסיבי) - (ב) **nmap** → **Scanning**
Enumeration & - (ג) מחיקת לוגים → **Covering Tracks** - (ד) הוספת משתמש לחזרה → **Maintaining**
Access - (ה) Exploit ב- **Gaining Access** → Metasploit

חלק ב' — הקמת הסביבה

פתרון 2.1 — התקנה עקוב אחר סעיף 1.7 ב-**README**. לאחר **Play Virtual Machine**, התחבר עם **kali / kali**. פתח **Terminal** מסרגל הכלים או בקיצור **Ctrl+Alt+T**.

פתרון 2.2 — עדכון

```
sudo apt update && sudo apt full-upgrade -y
```

update מרענן את רשימת החבילות; **full-upgrade** מתקין את הגרסאות החדשות. הזן את הסיסמה **kali** כשתתבקש.

פתרון 2.3 — זיהוי IP

```
ip a
```

חפש את השורה **inet** תחת המתאם (למשל **eth0**), למשל:

```
inet 192.168.152.130/24
```

- **192.168.x.x** → שייך לטווח הפרטי **192.168.0.0/16**.
- (אם קיבלת **10.x.x.x** → טווח **10.0.0.0/8**; אם **172.16-31.x.x** → **172.16.0.0/12**).

פתרון 2.4 — **Snapshot** → **Take Snapshot** → **VM**, שם: **Kali-clean-install**. **למה חשוב:** אם תקיפה/עדכון ישברו את המערכת, אפשר לחזור למצב תקין בשנייה במקום להתקין מחדש.

חלק ג' — היכרות עם Kali

פתרון 3.1 — כלים לפי קטגוריה דוגמאות תקינות: **Information Gathering** → **nmap**; **Password Attacks** → **metasploit** → **hydra** / **john**; **Exploitation Tools** (כל כלי מהקטגוריה נכון).

פתרון 3.2 — **rockyou.txt**

```
ls -lh /usr/share/wordlists/  
# אם רחוק:  
sudo gunzip /usr/share/wordlists/rockyou.txt.gz  
wc -l /usr/share/wordlists/rockyou.txt
```

התוצאה: **14,344,392** סיסמאות (בגרסה הסטנדרטית). זהו ה-wordlist המפורסם ביותר לתקיפת סיסמאות.

פתרון 3.3 — קטגוריה → שלב - Information Gathering → שלב 1–2 (Recon / Scanning) - Exploitation
Tools → שלב 3 (Gaining Access) - Post Exploitation → שלב 4 (Maintaining Access) ולאחר-פריצה

חלק ד' — חשיבה מתודולוגית

פתרון 4.1 — תרחיש Acme - (א) Black Box — קיבלת מידע מינימלי בלבד (רק דומיין). - (ב) פרופיל: **תוקף**
חיצוני ללא פרטי גישה. - (ג) פעולה ראשונה: **איסוף מידע פסיבי** (WHOIS, תת-דומינים, OSINT) — שלב
1, Reconnaissance. לא קופצים ישר לסריקה.

פתרון 4.2 — סוגי Engagement - בדיקת עובדים בפשינג → **Social Engineering**. - בדיקת שרת web
חיצוני → **External Network / Web Application**.

פתרון 4.3 — שרת מחוץ ל-Scope אסור לתקוף אותו — הוא מחוץ ל-Scope, ותקיפתו אינה מורשית (ועלולה
להיות עבירה פלילית / הפרת חוזה). **מותר ומומלץ** לתעד את הממצא ולדווח ללקוח שהנכס קיים ונראה
פגיע, ולהמליץ להוסיפו ל-Scope בבדיקה נפרדת.

אתגר מסכם — קווים מנחים לפתרון

מסמך מלא ייכלול: 1. **מעבדה:** צילומי מסך של Kali + `ip a` (IP פרטי מסומן) + `uname -a` + Snapshot.
2. **טבלת מתודולוגיה:** למשל —

שלב	מטרה	כלי	דוגמה
Recon	איסוף מידע	hunter.io	מציאת מיילים
Scanning	מיפוי שירותים	nmap	<code>nmap -sV target</code>
Gaining Access	ניצול	Metasploit	הפעלת exploit
Maintaining	שמירת גישה	ssh-key	הוספת מפתח
Covering Tracks	ניקוי	—	מחיקת לוגים

3. תוכנית **Black Box** ל-**acme.com**: שורה לכל שלב (Recon פסיבי → סריקת nmap → ניצול חולשה → שתילת גישה → ניקוי + דוח).

4. **אתיקה**: המעבדה מבודדת (NAT/Host-Only) כדי לא לפגוע ברשת אמיתית; מסמכים נדרשים: Scope, RoE, NDA, מכתב הרשאה.

אם כיסית את כל אלה — עברת את המודול בהצלחה. המשך למודול 2.